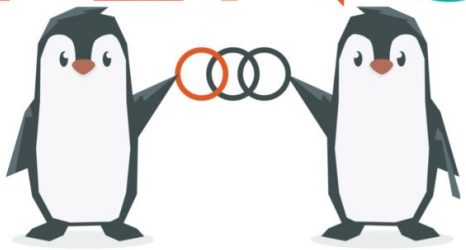
OPENCHAIN



BUILDING TRUST IN THE SUPPLY CHAIN SINCE 2016

SBOM Basic 2:
脆弱性発見時の対応フロー

Are you ready for CRA ? – SBOM –

この資料は有用であることを願って開示されますが、*全くの無保証* です。
内容の保証や特定の目的への適合性は、言外に示されたものも含め全く存在しません。

PUBLICDOMAIN
This slide is licensed under the Creative Commons Zero 1.0 Universal

脆弱性対応が必要な理由

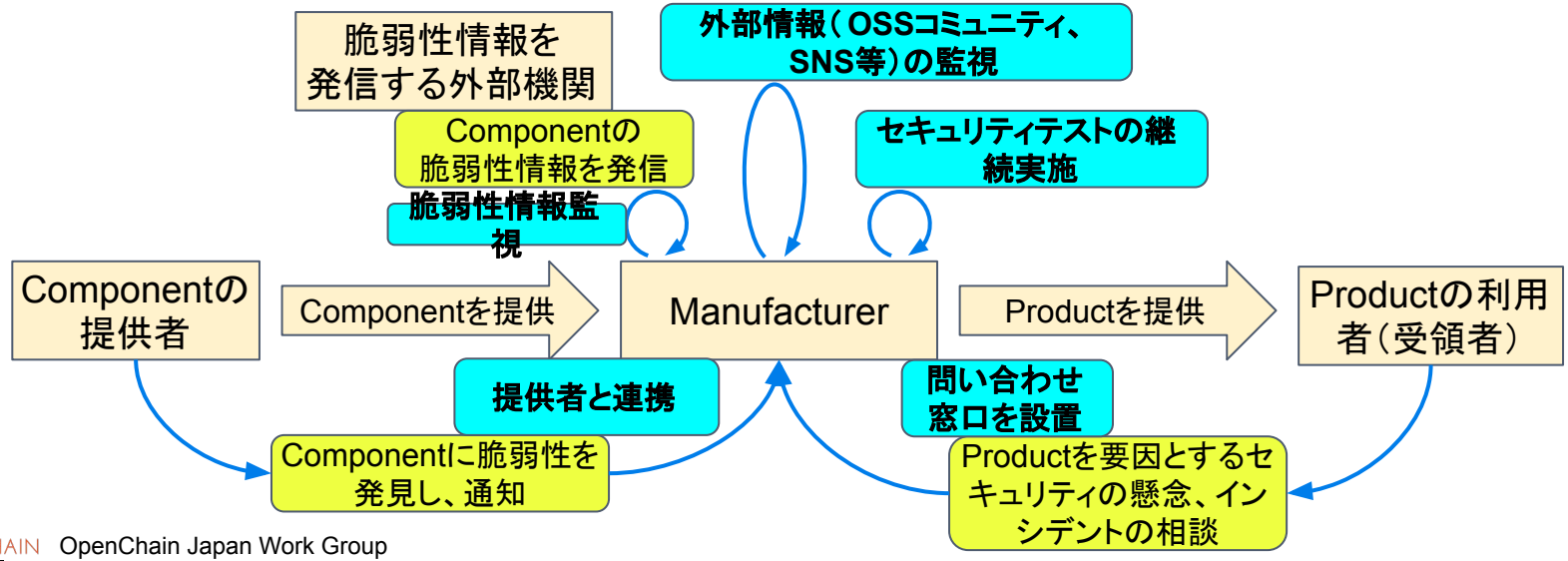
- システム障害が社会に及ぼす影響が非常に大きい
- ほとんどのシステムがネットワークにつながり、サイバーセキュリティ攻撃はどこからでも可能に
- 悪用されている脆弱性を見つけ次第、速やかに対処することが求められる

- EU CRAの対象となる「Product」とは
  - データ接続する（と想定される）ソフト、ハード、あるいは、リモートデータ処理ソリューションであって、
  - 完成品であるか、構成部品であるかは問わない、かつ、
  - EUで商業として提供されるもの
    - Article 2 Scope
      - 1. This Regulation applies to products with digital elements made available on the market, the intended purpose or reasonably foreseeable use of which includes a direct or indirect logical or physical data connection to a device or network.
    - Article 3 Definitions
      - (1) 'product with digital elements' means a software or hardware product and its remote data processing solutions, including software or hardware components being placed on the market separately

This slide is licensed under the Creative Commons Zero 1.0 Universal

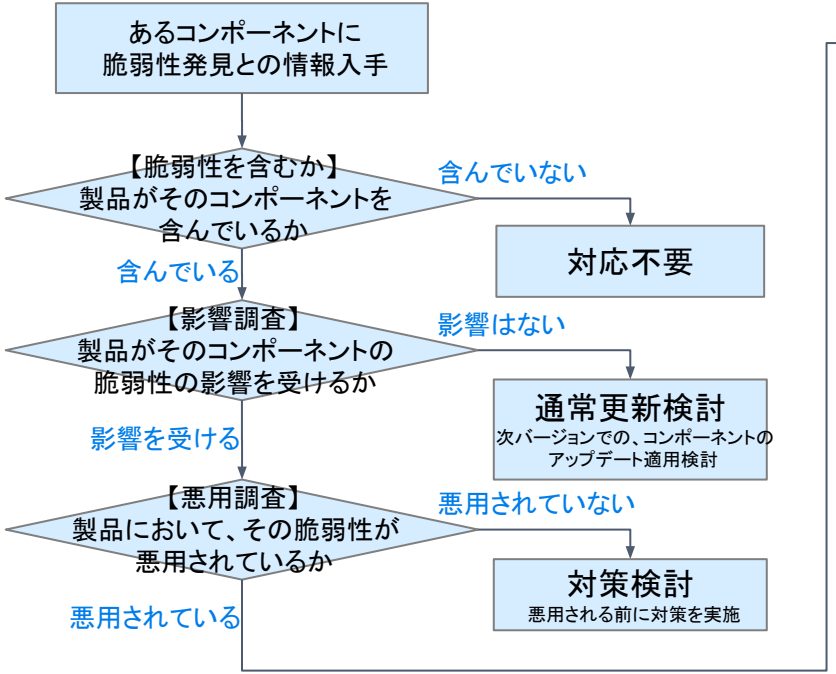
ProductのVulnerability＆Incident発見のきっかけ

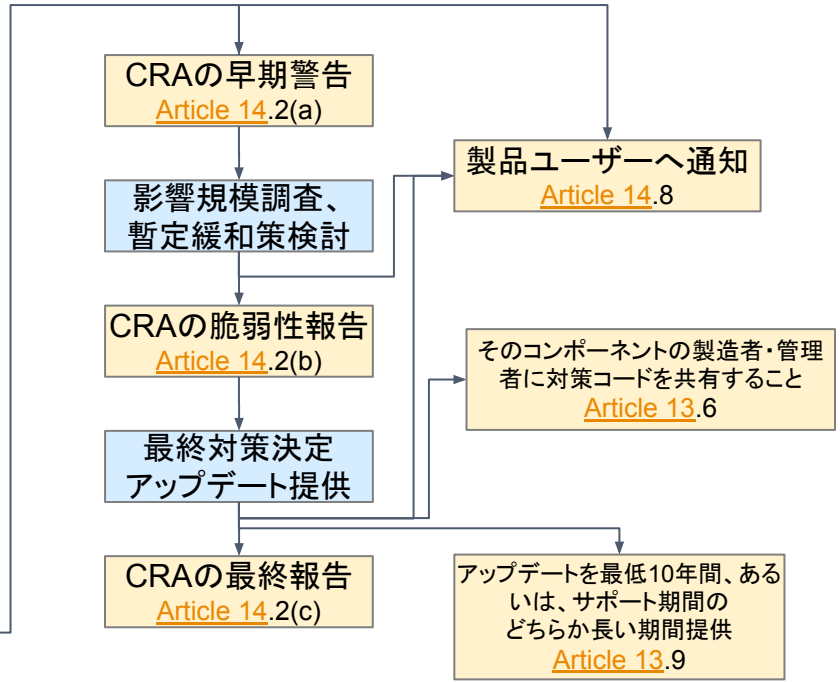
- 主体的に発見
  - 脆弱性情報監視、継続的なセキュリティテスト、外部情報（ OSSコミュニティ、SNS等）監視
- 受動的に発見
  - Component提供者からの通知、Product提供先からの問い合わせ



This slide is licensed under the Creative Commons Zero 1.0 Universal

脆弱性発見時の対応フロー



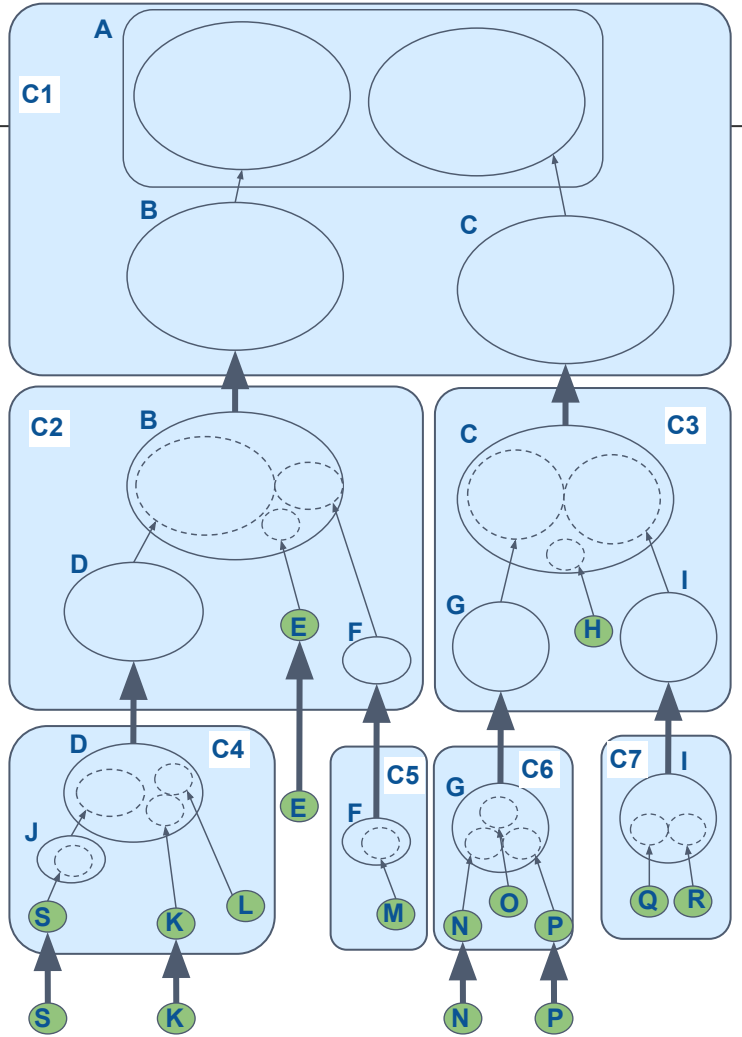


OPENCHAIN
PUBLICDOMAIN
OpenChain Japan Work Group
This slide is licensed under the Creative Commons Zero 1.0 Universal

対応フローのケーススタディ

右図のような構成のシステムで考えてみる

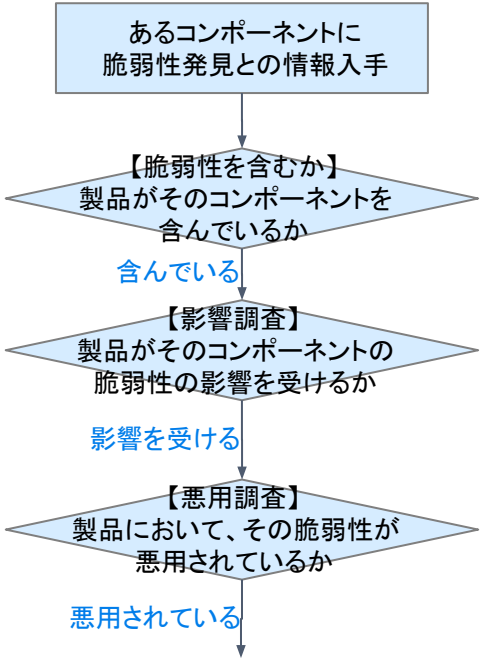
- Company 1 (C1)
  - A contains B and C
- Company 2 (C2)
  - B is generated from D, E and F
- Company 3 (C3)
  - C is generated from G and I
    - H is created by C3
- Company 4 (C4)
  - D is generated from S and K
    - D is generated from J, K and L
    - J is generated from S
- Company 5 (C5)
  - F is created by C5
    - F is generated from M
- Company 6 (C6)
  - G is generated from N and P
    - G is generated from N, O and P
- Company 7 (C7)
  - I is created by C7
    - I is generated from Q and R



OPENCHAIN
PUBLICDOMAIN
OpenChain Japan Work Group
This slide is licensed under the Creative Commons Zero 1.0 Universal

脆弱性発見時のシナリオ

Component Dに脆弱性発見との情報が発信された



Component Dに
脆弱性発見

↓

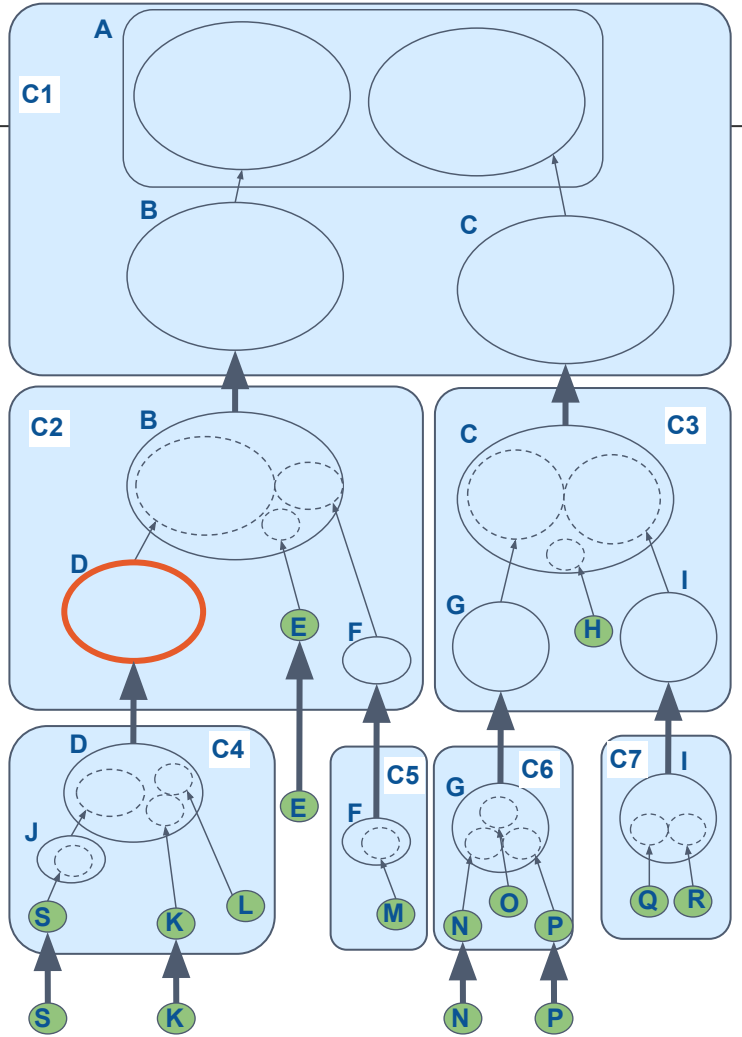
Component Bに
Component Dを
含んでいる

↓

BはDの脆弱性の
ある機能を利用し
ている

↓

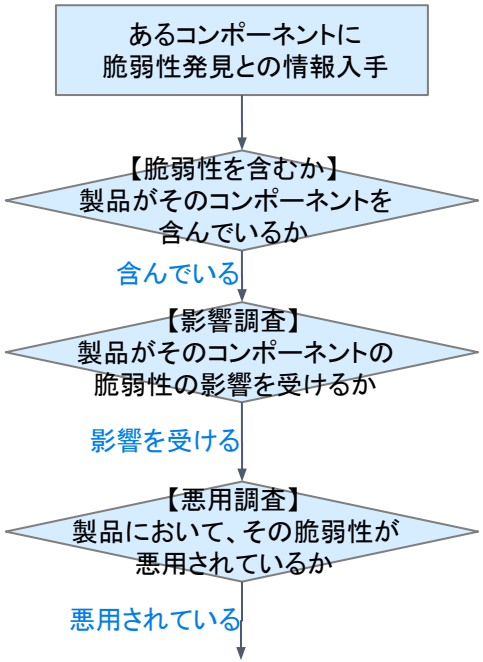
Product Aにおい
て、Bに含まれるD
の脆弱性が悪用さ
れていることが判
明



OPENCHAIN
PUBLICDOMAIN
OpenChain Japan Work Group
This slide is licensed under the Creative Commons Zero 1.0 Universal

脆弱性発見時のシナリオ

Company C1に、C2からComponent Bの構成情報が伝わっていないと、C2から連絡があるまで、C1は何もわからない

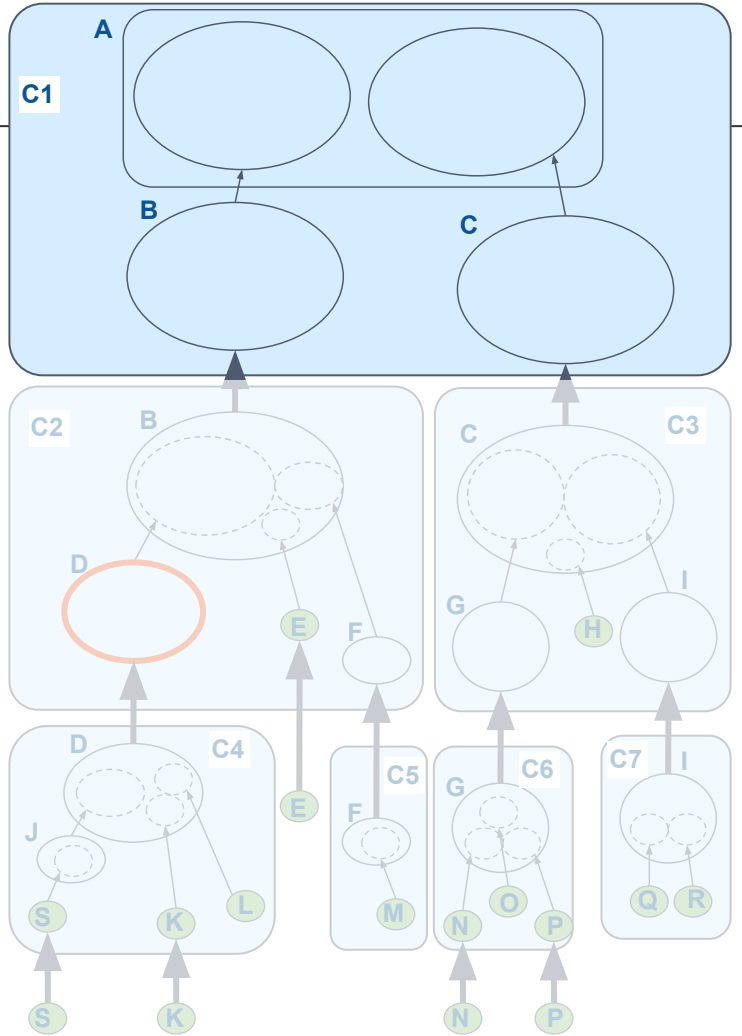


Component Dに
脆弱性発見

Component Bに
Component Dを
含んでいる

BはDの脆弱性の
ある機能を利用し
ている

Product Aにおい
て、Bに含まれるD
の脆弱性が悪用さ
れていることが判
明



OPENCHAIN
PUBLICDOMAIN
OpenChain Japan Work Group
This slide is licensed under the Creative Commons Zero 1.0 Universal

脆弱性発見時のシナリオ

サプライチェーンで構成情報（SBOM）が提供されていると、Company C1、C2とC4が同時にそれぞれの対応を並行して行うことができ、対応期間を短縮

Company C1

Component Dに脆弱性発見

↓

Component BにComponent Dを含んでいる

↓

C2への問い合わせと並行して、Product Aでの調査開始

↓

Product Aにおいて、Dの脆弱性が悪用されていることが判明

↓

Product Aにおいて、Bのアップデートを適用

Company C2

Component Dに脆弱性発見

↓

Component BにComponent Dを含んでいる

↓

BはDの脆弱性のある機能を利用している

↓

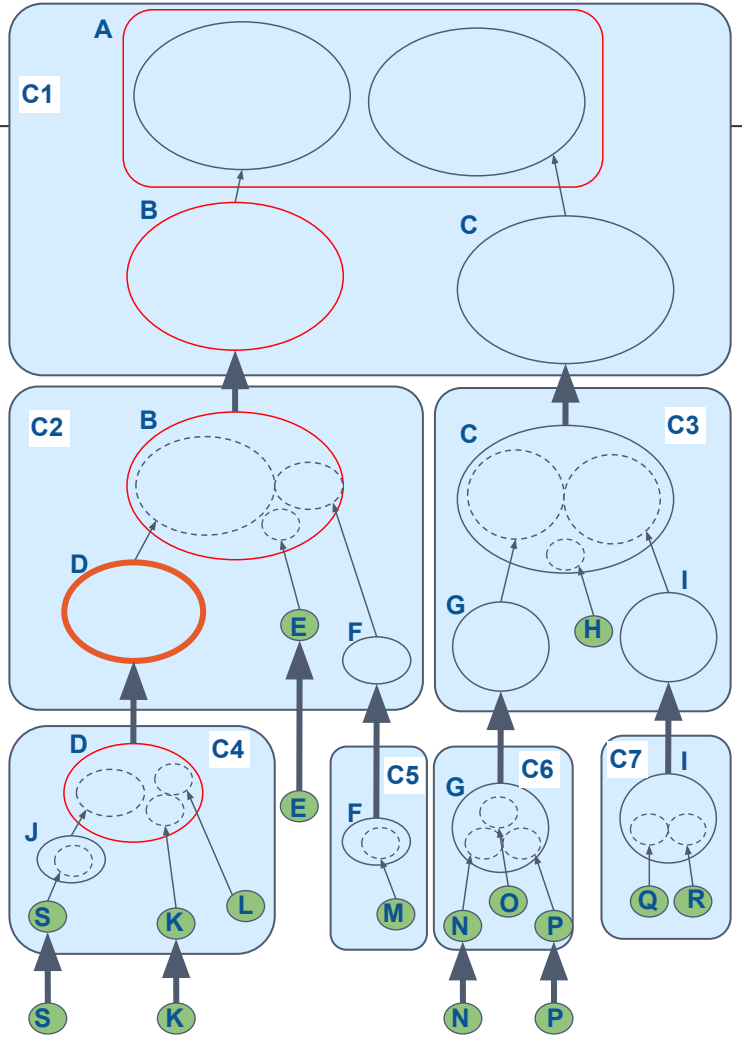
Bに含まれるDにアップデートを適用

Company C4

Component Dに脆弱性発見

↓

Dでの対策、アップデートを準備



OPENCHAIN
PUBLICDOMAIN
OpenChain Japan Work Group
This slide is licensed under the Creative Commons Zero 1.0 Universal

脆弱性の疑いのシナリオ

Product Aに脆弱性の疑い

Company C1

Product Aを調査し、Component Bに脆弱性の疑い

↓

Company C2に問い合わせ

Company C2

Component Bを調査し、Component Dに脆弱性の疑い

↓

Company C4に問い合わせ

Company C4

Component Dを調査し、Component Kに脆弱性を発見

↓

DにふくまれるKにアップデートを適用

↓

BにふくまれるDをアップデート

↓

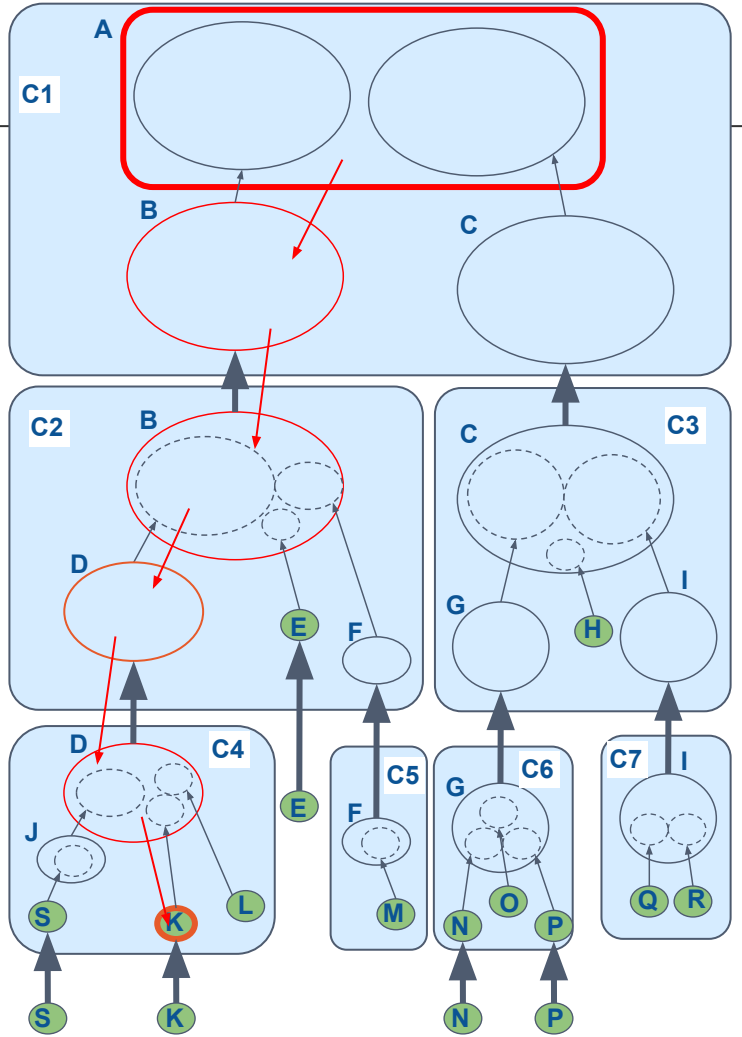
BにKの脆弱性の影響を確認

↓

Product Aにおいて、Kの脆弱性が悪用されていることを確認

↓

Product Aにおいて、Bのアップデートを適用



OPENCHAIN
PUBLICDOMAIN
OpenChain Japan Work Group
This slide is licensed under the Creative Commons Zero 1.0 Universal

サプライチェーン連携が求められている

- サプライチェーンの Entity間の連携が、迅速な脆弱性対応を実現する、という考え方
  - Componentと共にその構成情報（SBOM）が提供されることで、効果的な連携が可能
  - CRAでは、Productに含まれる第三者提供 Componentに脆弱性を発見した場合、Productの Manufacturerに、その脆弱性の対策を求めている
  - そしてその対策として行った、ソフト、ハードの修正コードやドキュメントを、その Componentの製造者・管理者に共有することを求めている

    ➡ つまり、Componentの製造者・管理者と共に利用者も一緒に脆弱性対応を行うという考え方

  - Article 13 Obligations of manufacturers
    - 6. Manufacturers shall, upon identifying a vulnerability in a component, including in an open source-component, which is integrated in the product with digital elements report the vulnerability to the person or entity manufacturing or maintaining the component, and address and remediate the vulnerability in accordance with the vulnerability handling requirements set out in Part II of Annex I. Where manufacturers have developed a software or hardware modification to address the vulnerability in that component, they shall share the relevant code or documentation with the person or entity manufacturing or maintaining the component, where appropriate in a machine-readable format.

PUBLICDOMAIN This slide is licensed under the Creative Commons Zero 1.0 Universal



OpenChain Project

Building Trust in Supply Chain sice 2016